UNIT 1 · TOPIC 1.4

AI-Based Cybersecurity Attacks

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. In a scenario where a relative receives a phone call from someone who sounds exactly like their family member asking for emergency bail money, yet the family member never made that call, which type of AI-powered attack does this illustrate?

- **● A. AI voice cloning used to impersonate the victim**
- ○ B. Automated vulnerability scanning
- ○ C. AI-generated phishing email
- ○ D. Deepfake video manipulation

Correct answer: A

Why: Voice cloning tools synthesize a person's voice from audio samples, in this scenario, scraped from the victim's public social media videos. The adversary used the cloned voice in a phone call to impersonate the victim and socially engineer a money transfer from a relative. This is an AI-powered vishing (voice phishing) attack, distinct from email phishing (C) or video deepfakes (D). Vulnerability scanning (B) is a reconnaissance technique unrelated to impersonation.

*Why the others are wrong: **B**, Vulnerability scanning is a reconnaissance technique that probes systems for weaknesses, it does not involve voice impersonation or social engineering via phone call. **C**, Phishing emails are text/link-based; this attack occurred over a phone call using synthesized voice audio, not an email. **D**, Deepfakes are video fabrications; the scenario describes audio-only impersonation over a phone call, which is voice cloning specifically.*

2. Which of the following best describes AI-generated phishing?

- ○ A. A human attacker manually writing each phishing email one by one
- **● B. The use of AI tools to automatically produce large volumes of personalized, convincing phishing messages**
- ○ C. Software that blocks suspicious emails before they reach the inbox
- ○ D. A hardware device that intercepts network traffic between a sender and recipient

Correct answer: B

Why: AI-generated phishing uses large language models or similar tools to mass-produce phishing messages that are personalized and stylistically convincing, mimicking real communication patterns, referencing the target's name or context, and scaling far beyond what a human attacker could produce manually. This makes attacks both more believable and more numerous than traditional hand-crafted phishing.

*Why the others are wrong: **A**, Manual, human-written phishing is the traditional approach AI-generated phishing replaces; it does not involve AI tools at all. **C**, Email blocking software is a defensive control, not an attack technique. **D**, A device intercepting network traffic describes a man-in-the-middle or packet-sniffing attack, not phishing.*

3. An adversary creates a realistic video of a company executive announcing a fake wire transfer authorization and sends it to the finance team. What category of AI-based attack does this represent?

- ○ A. Brute-force attack
- ○ B. SQL injection
- ○ C. Zero-day exploit
- **● D. Deepfake**

Correct answer: D

Why: A deepfake uses generative AI, typically deep learning models such as generative adversarial networks (GANs), to fabricate realistic video or audio of a real person. In a business context, deepfake videos of executives are used to

manipulate employees into authorizing fraudulent transactions. Brute-force (A) and SQL injection (B) are code-level attacks; zero-day exploits (C) target software vulnerabilities, none involve fabricated video.

*Why the others are wrong: **A**, Brute-force attacks systematically guess credentials or keys, they do not involve fabricated video content. **B**, SQL injection targets database input fields, not video-based social engineering. **C**, A zero-day exploit leverages an unknown software vulnerability, it does not describe a synthetic video fabrication.*

4. An employee receives an urgent email that uses their name, references a current internal project, and mimics their manager's writing style, asking them to click a link to approve a vendor payment. Which capability of AI tools most directly enables this level of personalization at scale?

○ A. AI tools encrypt phishing links to evade spam filters

○ B. Machine learning models brute-force email passwords to extract internal details before sending phishing messages

○ C. AI tools route phishing emails through multiple proxy servers to obscure their origin

● D. Large language models generate contextually coherent, targeted text by processing scraped organizational data such as employee profiles, project names, and public communications

Correct answer: D

Why: LLMs can ingest publicly available data, LinkedIn profiles, GitHub activity, press releases, social media, and generate phishing messages that reference genuine context: correct project names, authentic relationship hierarchies, and plausible writing styles. This contextual accuracy is what elevates AI-generated spear-phishing above generic template attacks. Encryption (A) and proxy routing (C) relate to obfuscation, not personalization. Password brute-forcing (B) is a separate attack technique and is not required to craft a convincing phishing message.

*Why the others are wrong: **A**, Link encryption can help phishing URLs evade some URL-scanning filters, but it does not produce the personalized content that makes the message convincing. **B**, Password brute-forcing is a credential-theft technique; constructing a contextually personalized phishing message requires scraped organizational data, not the target's password. **C**, Proxy routing obscures the attacker's identity and origin but has no bearing on how personalized or contextually accurate the message content is.*

5. Explain how AI-powered voice cloning attacks generate risk for both individuals and organizations.

○ A. Voice cloning attacks generate risk solely by overwhelming phone networks with spam calls, degrading call quality

○ B. Voice cloning generates risk only when combined with simultaneous physical theft of the impersonated person's device

○ C. Voice cloning poses risk only if the victim's voicemail PIN has already been compromised

● D. By enabling adversaries to impersonate trusted individuals in real-time phone calls, voice cloning can trigger unauthorized financial transfers, false emergency responses, or disclosure of sensitive information by deceived victims

Correct answer: D

Why: The risk of voice cloning lies in its erosion of trust in audio communication, a channel people instinctively treat as reliable identity evidence. When an adversary can synthesize a convincing voice, they can manipulate relatives into wire transfers, convince employees to bypass security procedures on a "manager's" instruction, or fabricate false emergency scenarios. None of these attacks require access to voicemail (C) or physical theft (B); they exploit the trust the recipient places in what they hear.

*Why the others are wrong: **A**, Volume-based spam calls are a denial-of-service nuisance, not the core risk of voice cloning; the danger is identity deception, not call volume. **B**, Voice cloning requires only audio samples (obtainable from public sources) and a phone call, no physical device access is necessary. **C**, Voicemail PIN compromise is a separate attack vector; voice cloning attacks are executed via direct live or pre-recorded calls, not voicemail access.*

6. How do automated AI attack tools change the threat landscape compared to traditional manual cyberattacks?

○ A. Automated AI tools eliminate the need for adversaries to have any technical knowledge, making cyberattacks equally accessible to all

● B. AI tools allow adversaries to conduct more attacks simultaneously, target more victims, and adapt attack content faster than manual approaches permit

○ C. AI tools reduce attack scale because they depend on limited training datasets and cannot generalize to new targets

○ D. Automated attack tools are effective only against large organizations since small targets lack sufficient data to fuel AI models

Correct answer: B

Why: The defining characteristic of AI-augmented attacks is multiplied scale and speed. Tasks that once required hours of manual effort, crafting a personalized phishing lure, identifying relevant targets, iterating based on what worked, can be parallelized across thousands of simultaneous targets. Adaptation cycles that previously took days (update the phishing kit, redistribute) can now happen in near-real-time. This does not eliminate skill requirements (A), designing and deploying effective AI attack tools still requires technical capability, and AI models can generalize across target types (C).

*Why the others are wrong: **A**, While AI tools lower some barriers, effective deployment of AI-augmented attacks (model selection, data collection, evasion tuning) still requires meaningful technical knowledge. **C**, Modern LLMs and generative models generalize across contexts rather than being locked to training data; they can produce novel, targeted content for previously unseen targets. **D**, Individuals are frequently targeted; voice cloning scams, for example, primarily target individuals and their relatives rather than large organizations.*

7. A security analyst observes a phishing campaign in which messages that were clicked in one wave are used to retrain the generation model for the next wave. Which combination of risks does this adaptive feedback loop introduce that a static phishing campaign does not?

● A. It allows the adversary to evolve attack content in near-real-time, systematically evading signature-based filters and improving click rates as the model learns which content bypasses current defenses

○ B. It increases bandwidth consumption and degrades corporate email infrastructure performance

○ C. It exposes the adversary to legal liability since retraining on click-interaction data constitutes unlawful processing of personal information in all jurisdictions

○ D. It limits the attack to organizations that rely primarily on email, excluding adversaries targeting other communication channels

Correct answer: A

Why: An adaptive feedback loop converts the target population into a live evaluation set. Successful message features are reinforced; detected or ignored patterns are discarded. This creates a moving-target problem for defenders: a detection rule effective against wave N may already be obsolete by wave N+1. Static phishing campaigns can be neutralized with a single signature update; adaptive campaigns require defenders to operate at or faster than the adversary's retraining cycle. Bandwidth impact (B) is incidental. Legal exposure (C) is a real concern in some jurisdictions but is not a risk introduced to the defender, it is a risk borne by the adversary. Channel restriction (D) is false; the same adaptive principle applies to SMS, voice, and other vectors.

*Why the others are wrong: **B**, The adaptive loop is a computational process on the attacker's infrastructure; it does not meaningfully affect the target organization's email bandwidth. **C**, Legal liability is a constraint on the adversary, not an increased risk to the organization being attacked. It does not alter the attack's effectiveness or the defender's risk profile. **D**, The adaptive feedback principle is channel-agnostic; it applies equally to SMS phishing (smishing), voice attacks, and social media as to email.*

8. In the voice-cloning scenario, the adversary accepted a social media connection request from the target and harvested voice samples over two weeks before executing the attack. Evaluate which combination of technical and behavioral vulnerabilities the adversary exploited across the full attack chain.

○ A. Technical: unencrypted phone network protocols; Behavioral: victim posted videos without audio watermarking

○ B. Technical: the cloning tool exploited a zero-day vulnerability in the social media platform's audio API; Behavioral: victim posted long-form podcasts that provided higher-fidelity voice samples

○ C. Technical: weak password on the victim's social media account allowing the adversary to access private posts; Behavioral: the relative failed to recognize the caller's phone number as unknown

● D. Technical: absence of AI-voice-detection capability on the recipient's phone; Behavioral: victim accepted a connection request from an unverified contact and posted voice-sampable public video; recipient did not verify the caller's identity through an independent channel before complying

Correct answer: D

Why: The attack required vulnerabilities at multiple layers. Technically, consumer phone infrastructure cannot flag synthesized voice audio, and the relative's device provided no AI-voice-detection capability. Behaviorally, the victim's failure to selectively vet connection requests gave the adversary reconnaissance access; publicly posted video content provided the raw audio material; the relative's failure to independently verify identity (e.g., terminating the call and dialing a known number) allowed the adversary to collect a fraudulent wire transfer. Option A misidentifies the technical vector, network encryption is irrelevant to a voice-cloning attack at the application/social layer. Option C conflates a credential-theft scenario with the actual attack, which required no account compromise. Option B attributes a capability (zero-day API exploit) not present in the scenario.

*Why the others are wrong: **A**, The phone network's encryption status is irrelevant, the attack succeeded at the social engineering layer, not through network interception. Audio watermarking is a future-state countermeasure, not an existing vulnerability the adversary exploited. **B**, No zero-day exploit was required; the adversary used standard social media browsing to collect public content and a commercially available voice-cloning tool. **C**, The adversary needed no account compromise, all audio samples were gathered from content the victim had already made publicly visible.*

9. An AI tool generates phishing emails by scraping a target organization's public GitHub repositories, employee LinkedIn profiles, and press releases to model internal project vocabulary and reporting relationships. Evaluate how this data-aggregation technique changes the risk profile of the resulting attack relative to a generic phishing campaign.

○ A. The risk profile is essentially unchanged; adequately trained users can still distinguish AI-generated from human-written emails

○ B. Risk is lower because AI-generated content lacks the emotional authenticity of human writing and is therefore easier to flag as suspicious

○ C. Risk only increases for organizations with more than 500 employees, since smaller organizations produce insufficient public data to meaningfully train a model

● D. The aggregated-data approach significantly raises the risk profile: contextual accuracy, correct project names, authentic relationship references, plausible internal vocabulary, defeats the user's most reliable recognition heuristic and substantially increases compliance probability before technical controls can intercept

Correct answer: D

Why: The core risk escalation is epistemic: the attack defeats the user's most reliable internal heuristic, "does this message know things only a genuine colleague would know?" Contextual accuracy derived from aggregated public sources makes the message internally consistent in ways generic phishing cannot replicate. This shifts the primary detection burden from the user to upstream technical controls (behavioral email filtering, authentication protocols), which themselves may not flag a well-formed, contextually plausible, low-volume message arriving from a legitimately registered domain. Option A underestimates the difficulty of distinguishing contextually accurate AI-generated content from authentic communication. Option B is contradicted by empirical evidence, current LLM-generated text regularly passes human authenticity evaluations. Option C is unsupported; an individual target's public footprint (LinkedIn, GitHub, Twitter) can be sufficient to generate a highly effective spear-phishing message regardless of organizational size.

*Why the others are wrong: **A**, Training users to spot template-based phishing is qualitatively different from training them to detect contextually accurate AI-generated messages; the latter is a much harder cognitive task. **B**, Empirical evaluations consistently show that LLM-generated text achieves high human-authenticity ratings; emotional register is not a reliable discriminator between AI and human writing at current capability levels. **C**, An individual's own public social media, professional profiles, and code repositories can be sufficient for a targeted attack; organizational size is not the limiting variable.*

10. Which of the following is a security control that can help protect individuals from AI-powered voice cloning scams like the one in which a relative was deceived into wiring money?

- **● A. Establishing a family-specific code word known only to trusted contacts, used to verify the identity of any caller making an urgent request**
- ○ B. Disabling automatic software updates on all devices
- ○ C. Encrypting the hard drive of the intended impersonation victim's computer
- ○ D. Enabling location services on the victim's mobile device

Correct answer: A

Why: A shared secret code word is an out-of-band identity verification control. If a caller, however convincing the voice sounds, cannot provide the code word, the recipient knows not to comply. This directly counters voice cloning because the adversary, who obtained voice samples but no insider knowledge, cannot produce the pre-shared secret. The other options address unrelated risks: hard drive encryption (C) protects stored data, location services (D) have no bearing on voice authentication, and disabling updates (B) is a security liability, not a control.

*Why the others are wrong: **B**, Disabling automatic updates removes a critical security control that patches known vulnerabilities, it increases risk rather than reducing it. **C**, Full-disk encryption protects data at rest on a device; it has no effect on the authenticity of a phone call. **D**, Location services track geographic position; they provide no mechanism for verifying the identity of a voice caller.*

11. To reduce the risk of an adversary harvesting voice samples from public social media to fuel a cloning attack, which control is most directly relevant?

- **● A. Reviewing and restricting the audience of video posts that contain the user's voice**
- ○ B. Installing antivirus software on all devices used to access social media
- ○ C. Using a strong, unique password on the social media account
- ○ D. Enabling two-factor authentication on linked email accounts

Correct answer: A

Why: Restricting the audience of voice-containing posts (e.g., setting them to friends-only or private) limits which parties can access and download those audio samples, directly reducing the input material the adversary's cloning tool depends on. Strong passwords (C) and 2FA (D) protect account access but do not prevent an adversary who can already view public posts from downloading and using the audio. Antivirus (B) scans for malware; it does not control who can view or download posted content.

*Why the others are wrong: **B**, Antivirus software detects malicious files on a device; it does not control the visibility or accessibility of content posted publicly on a social media platform. **C**, A strong password prevents unauthorized login to the account, but if content is already public, anyone can view and save it without needing account credentials. **D**, Two-factor authentication protects account access; it does not affect the visibility of content that is already set to public.*

12. Which security control is specifically designed to help verify whether an email was actually sent by the domain it claims to be from, a check directly relevant to AI-generated phishing that spoofs legitimate senders?

- ○ A. Full-disk encryption on the recipient's computer
- **● B. Email authentication protocols such as SPF, DKIM, and DMARC**
- ○ C. A VPN connection when checking email
- ○ D. Endpoint antivirus scanning of email attachments

Correct answer: B

Why: SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance) are email authentication standards that let receiving mail servers verify that an email was sent from an authorized server for the claimed sending domain. They directly counter spoofed sender addresses, a common tactic in AI-generated phishing where the "From" field mimics a legitimate organization. The other controls address different threat surfaces: disk encryption protects stored data, VPNs encrypt transit traffic, and antivirus scans file contents, none of which verify sender identity.

*Why the others are wrong: **A**, Disk encryption protects data stored on the device from physical access; it does not verify the origin of incoming email messages. **C**, A VPN encrypts the connection between the user's device and the VPN server but does not inspect or authenticate the sender identity of email messages. **D**, Antivirus scans can detect malicious attachments or known-bad URLs, but they do not authenticate the identity of the sending domain for legitimate-looking phishing emails without attachments.*

13. Explain how AI-powered email filtering tools mitigate the risk of AI-generated phishing at a higher level of effectiveness than traditional signature-based spam filters.

○ A. AI filters detect AI-generated emails by analyzing keyboard timing metadata embedded in email headers

● B. AI-powered filters analyze behavioral and semantic patterns, unusual sending cadences, linguistic drift from the claimed sender's history, anomalous link structures, enabling detection of AI-generated phishing even when the content lacks any previously catalogued malicious signature

○ C. AI filters rely on the same blacklisted-IP mechanism as traditional filters, but execute the lookup faster

○ D. AI filters prevent phishing by encrypting all inbound email automatically, making embedded links unclickable

Correct answer: B

Why: Signature-based filters match incoming messages against a database of known-bad patterns (malicious URLs, known phishing templates). AI-generated phishing is specifically designed to be novel, avoiding those catalogued patterns. Behavioral AI filtering instead analyzes properties that are harder for the attacker to control: the statistical distribution of sending times, whether the message's language style is consistent with the purported sender's previous communications, whether links resolve to domains with recent registration dates, and whether message content clusters with known phishing semantic patterns. These emergent properties are observable even in first-seen attacks. Keyboard timing metadata (A) is not transmitted in standard email headers. Blacklist lookups (C) are exactly the mechanism AI filtering is meant to supplement. Encrypting inbound email (D) would break legitimate email workflows and does not address the phishing threat.

*Why the others are wrong: **A**, Email protocols do not capture or transmit keyboard timing information; this metadata is not available to email filtering systems. **C**, If AI filtering simply performed faster IP blacklist lookups, it would provide no additional protection against novel phishing content from unlisted sources, which is precisely where AI-generated phishing operates. **D**, Encrypting inbound email would prevent users from reading legitimate emails and does not prevent phishing; the threat is social deception, not the absence of encryption.*

14. A company wants to protect employees from deepfake video calls in which an adversary impersonates an executive to authorize fraudulent financial transactions. Which combination of security controls best addresses this specific threat?

○ A. Firewall rules that block video conferencing ports, combined with mandatory antivirus scans on all incoming video files

● B. Multi-person authorization policies requiring more than one approver for high-value transactions, combined with out-of-band identity verification before acting on instructions received via video call

○ C. Requiring all executives to use personal email accounts for sensitive financial communications instead of corporate video platforms

○ D. Installing deepfake-detection software on employee devices and blocking all video conferencing platforms

Correct answer: B

Why: Multi-person authorization (a procedural control) ensures no single deepfake call can unilaterally authorize a transfer, even a perfect deepfake cannot satisfy a policy requiring two independent human approvers. Out-of-band identity verification (e.g., terminating the call and ringing the executive back on a known direct line) provides identity assurance through a channel the adversary does not control. Together these controls do not depend on detecting whether a video is fake. Blocking video conferencing entirely (D) disrupts legitimate business operations. Antivirus on video files (A) addresses file-based malware, not live call impersonation. Routing executives to personal email (C) removes security controls and accountability that corporate systems provide.

*Why the others are wrong: **A**, Antivirus scanning video files targets file-borne malware; a live deepfake video call does not involve a file being delivered to the employee's system for scanning. **C**, Moving executives to personal email removes audit trails, encryption standards, and authentication controls that corporate systems enforce, this increases rather than reduces risk. **D**, Blocking all video conferencing*

would impose severe operational disruption without proportionate benefit; and deepfake detection software alone can be evaded as generation models improve.

15. Determine which security control primarily addresses the social engineering vulnerability exploited in AI-augmented attacks, as distinct from technical or infrastructure vulnerabilities.

● A. Security awareness training that specifically covers AI-powered attack techniques, voice cloning, deepfakes, AI-generated phishing, and trains users to apply independent verification before acting on urgent requests

○ B. Patching the operating system and all installed applications to the latest available version

○ C. Enabling full-disk encryption on all company-issued devices

○ D. Deploying a web application firewall in front of all public-facing services

Correct answer: A

Why: AI-augmented attacks such as voice cloning and deepfake impersonation succeed primarily by exploiting human cognitive patterns, urgency, familiarity with a voice or face, deference to authority, not by exploiting software vulnerabilities. A technical patch (B), disk encryption (C), or a WAF (D) addresses unrelated attack surfaces and provides no protection when the vulnerability is the user's judgment under deception. Security awareness training that names specific AI techniques and establishes verification habits equips users to apply appropriate skepticism even when content appears legitimate, targeting the human-judgment layer where these attacks actually operate.

*Why the others are wrong: **B**, OS patches close software vulnerabilities; they do not affect a user's ability to recognize or resist a socially engineered voice call or convincing phishing email. **C**, Full-disk encryption protects stored data from physical device compromise; it has no bearing on an employee's response to a deceptive phone call or video. **D**, A WAF inspects and filters HTTP/S traffic to web applications; it operates at a different layer and cannot intercept or evaluate the social engineering dynamics of a phone call or email.*

16. A security architect proposes the following control set to defend financial authorization workflows against AI voice cloning: (1) Deploy voice-biometric authentication on all inbound calls to the finance department. (2) Train employees to question urgent requests made by phone. (3) Log all inbound calls to the finance department. Evaluate this control set and identify the most critical gap it leaves unaddressed.

○ A. The set omits full-disk encryption, which is required for call log integrity

○ B. Logging inbound calls violates data protection regulations in most jurisdictions, making Control 3 legally impermissible

● C. Voice-biometric authentication is itself potentially vulnerable to a sufficiently high-fidelity voice clone; if the biometric model has not been adversarially evaluated against AI-generated voice samples, Control 1 may provide false assurance rather than genuine verification

○ D. The three controls are redundant with one another and can be simplified without any reduction in coverage

Correct answer: C

Why: Voice-biometric systems compare an incoming voice signal against an enrolled sample to verify identity. If the adversary's cloning tool produces audio that falls within the biometric model's acceptance threshold, authentication passes, even for a synthetic voice. The control set as proposed treats voice biometrics as a reliable backstop without acknowledging that the same AI-generation technology the biometric is meant to detect may exceed the system's discrimination capability. The architect must either (a) supplement with knowledge-based or physical possession factors, creating genuine multi-factor verification, or (b) confirm the biometric vendor has evaluated model robustness specifically against adversarial AI-generated voice inputs. Disk encryption (A) is unrelated to call authentication. Call logging may be regulated in some jurisdictions but is commonly permitted with disclosure (B) and is not the primary gap. The three controls address different threat sub-layers and are not redundant (D).

*Why the others are wrong: **A**, Disk encryption protects stored data; call log integrity is a separate concern addressed by log-integrity mechanisms such as append-only storage or cryptographic hashing, not disk encryption per se. **B**, Call recording regulations vary significantly by jurisdiction and context; many organizations lawfully record calls with appropriate consent or disclosure. Even where regulated, this is a compliance constraint, not the primary security gap in the control set. **D**, The three controls operate at distinct layers, biometric authentication (identity verification), training (human judgment), and logging (post-incident forensics), and address different failure modes; they are complementary, not redundant.*

17. An organization implements the following layered control set against AI-generated phishing: (1) DMARC, DKIM, and SPF email authentication. (2) AI-powered behavioral email filtering. (3) Mandatory security awareness training updated once per year. (4) Multi-factor authentication on all accounts. Evaluate which residual risk remains most significant despite this control set.

- **● A. A highly contextualized, low-volume spear-phishing message sent from a legitimately authenticated domain, or a lookalike domain just outside SPF/DKIM coverage, can satisfy both authentication and behavioral anomaly thresholds; annual training may not have equipped users to detect contextually accurate, AI-generated content that the technical layers have already passed**
- ○ B. DMARC, DKIM, and SPF operate only on inbound email and provide no protection against reply-chain hijacking attacks
- ○ C. MFA cannot be deployed on corporate email accounts, making it ineffective against phishing regardless of how it is configured
- ○ D. AI-powered behavioral filters require a minimum of six months of baseline traffic data, during which the organization has no phishing protection at all

Correct answer: A

Why: Authentication protocols verify sending infrastructure, not the semantic intent of the message; a legitimately registered lookalike domain passes authentication checks. Behavioral AI filtering flags statistical anomalies, but a carefully crafted, low-volume, contextually accurate spear-phishing message may exhibit no anomalous sending behavior (it looks like normal business correspondence). Annual training updates lag adversarial capability evolution; users trained on last year's phishing archetypes may not recognize this year's AI-aggregated, contextually authentic variant. MFA mitigates account takeover after a credential is compromised but cannot prevent a user from clicking a link or initiating an unauthorized action if they genuinely believe the message is legitimate. The residual risk is a small, high-precision attack that satisfies all four layers by virtue of its technical legitimacy and contextual accuracy.

*Why the others are wrong: **B**, Reply-chain hijacking is a real attack vector, but it is a separate concern from the residual risk of AI-generated spear-phishing that this control set leaves unaddressed. **C**, MFA can and routinely is deployed on corporate email accounts; even where it is, it reduces post-compromise impact rather than preventing the initial deception. **D**, AI behavioral filtering systems typically begin generating signals from day one, with baselines improving over time; a "no protection for six months" claim is not a standard characteristic of enterprise email filtering deployment.*

18. A security team is evaluating whether to invest in a real-time AI deepfake-detection tool for their video conferencing platform versus strengthening procedural controls, multi-person authorization, callback verification, and out-of-band approval workflows. Evaluate the relative long-term durability of these two approaches given the co-evolutionary nature of AI generation and detection.

- **● A. AI deepfake detection and generation models co-evolve in an adversarial arms race; detection capability at any point in time may be outpaced by advances in generation. Procedural controls impose a verification burden that is independent of deepfake quality and therefore provide more durable protection, though they introduce friction and may not scale to all interaction types**
- ○ B. Procedural controls are unambiguously superior because AI detection tools have been proven ineffective in all real-world deepfake deployment scenarios to date
- ○ C. The AI detection tool is unambiguously superior because it operates at machine speed and does not depend on human judgment, which is inherently error-prone
- ○ D. Neither approach is effective against sophisticated adversaries; organizations should ban video conferencing and replace it with in-person meetings for all sensitive decisions

Correct answer: A

Why: Detection and generation AI are co-evolutionary: as detection models improve, generation models are fine-tuned to evade them, this dynamic is well-documented in the academic literature on generative adversarial networks and adversarial robustness. A detection tool that is effective today may be obsolete within a product cycle as adversaries retrain generation models against the published or reverse-engineered detector. Procedural controls, requiring a second

authorizer, verifying identity through a pre-established independent channel, do not require distinguishing real from fake video; they impose a structural burden that an adversary must bypass regardless of how realistic the deepfake is. The trade-off is that procedural controls add latency and friction, making them less suitable for high-frequency, low-stakes interactions. The optimal organizational posture layers both, calibrated to the risk level and frequency of different transaction types, rather than treating either approach as a single sufficient solution.

*Why the others are wrong: **B**, Claiming deepfake detection tools are universally ineffective is an overstatement; current tools provide meaningful signal, particularly against lower-fidelity fakes. The issue is long-term durability and co-evolutionary dynamics, not absolute current ineffectiveness. **C**, Machine-speed detection is only an advantage if the detection model is accurate; in the adversarial co-evolution dynamic, a detection model that was accurate last quarter may have a high false-negative rate today as generation models advance. **D**, Banning video conferencing imposes severe operational constraints with no durable security justification; adversaries capable of deepfake video calls are also capable of adapting to other channels. Procedural controls are channel-agnostic and provide protection without eliminating the communication medium.*